UTM UNIVERSITI TEKNOLOGI MALAYSIA RESEARCH UNIVERSITY	**FACULTY OF COMPUTING** **UNIVERSITI TEKNOLOGI MALAYSIA**

PSM 1 (SEC_3032)
PROJECT PROPOSAL & SUPERVISION CONSENT FORM

Session/Semester: 20252026/2

Instruction: Please complete and submit to your program PSM1 committee member.
Student: Please complete student information in detail. The proposal must be reviewed by the supervisor before submission.
Supervisor: Please complete your consent, signature, stamp and date. Please review student's proposal before submission.

SECTION A: STUDENT INFORMATION

Name:	Mohamed Omar Mohamed Gad Makhlouf		
Year/Course:	**3/SECRH**		
IC. No.:	202210M10298	**Matrix No.:**	A23CS4014
Email:	omarmohamed.m@graduate.utm.my	**Mobile No.:**	+60 11-1138 3171
CGPA: 3.31	**Date:** 14/04/2026	**Signature:**	

SECTION B: SUPERVISOR CONSENT

Supervisor Name:	Johan Mohamad Sharif		
Email:	johan@utm.my	**Mobile No.**	+60 11-2136 0472
Consent:	I **AGREE** to be an Undergraduate Supervisor for this student with the proposed title that I have reviewed.		
Signature & Official Stamp:	DR JOHAN BIN MOHAMAD SHARIF DEPARTMENT COMPUTER SCIENCE FACULTY OF COMPUTING UNIVERSITI TEKNOLOGI MALAYSIA 81310, UTM SKUDAI MALAYSIA	**Date:** 15 April 2026	

SECTION C: PROJECT DETAILS

Project Title:	Design and Deployment of a Secure Cloud-Based Patient Data Management System using a Three-Tier Architecture on AWS
Proposal No.*	1
Project Idea:	[✓] My own idea [ ] Proposed by the supervisor
Project Type:	[✓] System Development

Video Presentation Link: https://youtu.be/2Dx5dX3fLVw

1. Problem Background and Proposed Solution:

Currently, most healthcare facilities still run their operations on physical (on premises servers). Where this was the standard model for years, the issue comes in scaling and maintaining this environment, since it's hard to scale and slow in updating physical hardware(Argaw et al., 2019). In this setup manual patching and monitoring is time consuming and is subjected to human error. The primary stakeholder for this project is a private healthcare provider, namely Alamin Clinic (Saudi Arabia), which is used as a case study to guide the system design and requirements. The system is intended to support key users including **doctors, administrative staff, and patients**, ensuring the secure management of patient data and healthcare operations.

The threat of this model became reality when the Alamin Clinic system was hit by a ransomware attack. Therefore, due to an outdated infrastructure, attackers were able to encrypt patient data and demand a ransom, which proves that the current system and its security measures are not only old but vulnerable to threats. In a healthcare facility (Al-Issa et al., 2019) a system crash or data breach is critical, and its effects on doctors and patients can be severe. Unless we move towards a safer and more automated system, the Clinic will continue to be a vulnerable when the next attack takes place. The solution is to have a way of making sure that patient records are always accessible, encrypted, and compliant with standards like HIPAA without necessarily having to use manual procedures.

Therefore, in order to mitigate these risks, the system aims to create a Clinic Record Management System (CRMS) in the cloud, which will be designed and deployed in a secure manner using a 3-tier architecture on (AWS). This will enable the clinic to migrate from the current architecture to a Virtual Private Cloud,

which will provide the security benefits of private subnets, inaccessible from the public Internet. Furthermore, the system will utilize Infrastructure as Code (IaC) using Terraform, which will enable the system to create a secure, and automated environment, eliminating the need to manually configure the infrastructure, which can lead to human errors. Moreover, the project will utilize DevSecOps, which will automatically scan system for vulnerabilities before the code is deployed, thus protecting the Clinic from the threat of ransomware in the future.

1.1 System security measurement.

Based on the proposed solution the following security metrics will be used to evaluate the secure cloud:

- Access control validations (IAM ROLES and RBAC) role-based access management
- Network isolation and data layer security in the private subnets
- Data encryption at REST and TRANSIT using AWS KMS/AES
- Vulnerability scanning results from SonarQube, Trivy and OWASP in the Devsecops pipeline
- Monitoring and logging via AWS services like cloud watch, CloudTrail and external services Prometheus & Grafana for metric and alerts
- Compliance Audit: Measure the system against a HIPAA-compliance checklist using AWS Security Hub (Ahuja et al., 2012)
- Recovery Time: Measure how fast you can redeploy the entire environment using Terraform after a simulated "ransomware" wipe.

2. Literature Review

2.1 Comparison of Existing Systems

To get a better understanding of the current environment, I compared various existing systems with the proposed secure cloud system I am developing.

System	Key Features	Main Limitations
Traditional On-Premise HMS	Control over data, no internet connectivity needed	High ransomware vulnerabilities, manual updates, hardware costs
OpenEMR (Open Source)	Patient portals, scheduling, billing	Reactive security, manual updates, servers needed
Epic Systems (Commercial)	All in one clinical solution with professional support	Extremely high costs, making it unaffordable for most clinics
Proposed System (Alamin Clinic)	3-Tier AWS + DevSecOps Automation, **Shift-Left Security"** (scanning before deployment), Security by design	Focus on infrastructure security instead of extensive billing features.

2.2 Case Study: Alamin Clinic (Saudi Arabia) Current Workflow

Most traditional systems now operate in isolation manner, where different components do not share nor communicate data properly. The following is the traditional system's workflow that often leads to vulnerabilities experienced by the Alamin clinic:

Current Workflow:

1. Manual Server Configuration: The system's physical server is manually set up by IT staff in a physical facility which is prone to human error.
2. Development to Production: The code is manually transferred to the server by the developer via an FTP client or USB drive. This often leads to human error and delay in deployment.
3. Local Hosting: The entire system is hosted on a single server for web, applications, and databases.
4. Reactive Security: Firewalls and Antivirus software are manually updated. This often leads to human error, and if a security patch is missed, it leaves the system vulnerable.

Reason for Failure:

The system is flat and manual, thus leaving it vulnerable to ransomware attacks that will encrypt the entire database in an instant due to the absence of network isolation.

2.3 Technology to be Employed

To address the issues in the system, the project will employ three modern technological pillars(Paidy & Chaganti, 2024):

1. Three-Tier Architecture on a VPC : The system will be divided into three sections. The first will be the presentation layer (frontend), the second will be the application layer (backend running on EC2), and the third will be the data layer (RDS database). This will ensure that in case the frontend is compromised, the database will be safe in a private subnet.
2. Infrastructure as Code (Terraform): Terraform will be used to automatically set up the network in a blueprint format. Which transfer the architecture to be **"Self-Healing"** meaning it can be redeployed instantly from code after an attack.
3. DevSecOps Pipeline: A CI/CD pipeline is being set up (GitHub actions). The pipeline will be designed to automatically scan for vulnerabilities. If there is a security flaw in the code, it will be automatically detected and will prevent the deployment.

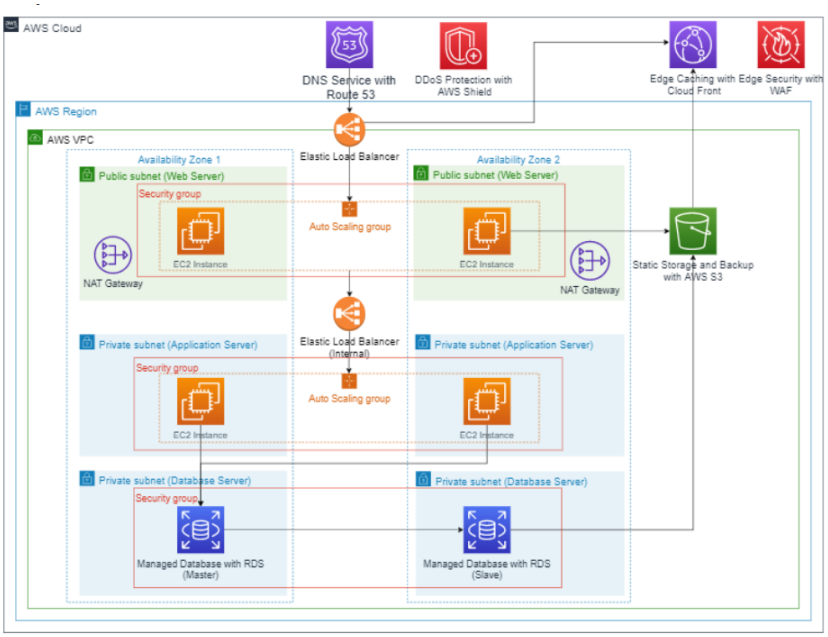

Figure 1

2.4 Comparison of Standard AWS architecture

Many AWS architecture exist but what makes them different is the ability to design and build a sophisticated architecture based on the business needs. where AWS offers a large number of services from AZ, VPC to storage and monitoring, AWS doesn't guarantee security as per their policies below:

> "The AWS Cloud enables a **shared responsibility model**. While AWS manages security of the cloud, you are responsible for security in the cloud. This means that you retain control of the security you choose to implement to protect your own content, platform, applications, systems, and networks no differently than you would in an on-site data centre."

My system is combination between:

- **Saas** : web app, users.
- **Iaas** : The system is built and deployed on cloud provided by AWS, with additional DevSecOps practices for automation and security)
- **Automation :** Using Devsecops (shifting left principles) and security by design mindset .

Feature	**Standard AWS Architecture**	**The Proposed Solution (Alamin Clinic)**
Deployment	Often manual or uses basic scripts.	**Fully Automated** via Terraform (IaC).
Security	Typically added after the system is built.	**Shift-Left Security** (Scanned during CI/CD).
Recovery	Requires long manual rebuilds after an attack.	**Instant Redeployment** from a secure blueprint.
Data Protection	Basic private subnets.	**Hardened Network ACLs + Private RDS Isolation**.

3. Objectives:

The aim of the proposed project is to develop a secure cloud-based Patient Data System on AWS (Singh & Chatterjee, 2015) in the form of a three-tier architecture that include:

1. To investigate concepts as cloud computing and cloud security, three-tier architecture, network segmentation, and secure system design of healthcare applications.
2. To develop a secure design of the Cloud-Based Patient Data management system based on a three-layer architecture on AWS, including networking, access control (IAM), and DevSecOps.
3. To evaluate the security, performance, and scalability of the system using automated security scanning and Recovery Time stress-testing.

4. Scope:

This project focuses on the Secure Patient Data Management System specifically designed for doctors, administrative staff, and patients. The system will be fully deployed on AWS as a functional prototype, not a simulation or local hosting, with evidence provided through security scan reports, CloudWatch logs, and recovery time test results. The patient data management system will consist of the following

functional modules: Patient Registration, Medical Records Management, Appointment Scheduling, and User Authentication & Role Management (Doctor, Admin, Patient). In addition, the system will include the following technical support modules: Cloud Infrastructure, Security & Compliance, DevSecOps Pipeline, and Monitoring & Automated Recovery. The technical scope includes:

In-Scope:

- Core patient record management functionality
- Design of a Virtual Private Cloud (VPC) with public and private subnets
- Three-tier architecture consisting of a frontend layer, a backend layer, and a database layer
- AWS services including VPC, EC2, RDS, and a load balancer
- Security layers including network security (security groups and ACLs), AWS Identity and Access Management (IAM and RBAC)
- Encryption at Rest (AES/KMS) and In Transit (TLS/HTTPS)
- DevSecOps CI/CD pipeline using GitHub Actions, Docker, and Terraform, with automated build and staging deployment, along with security scanning for both container images and source code
- Monitoring mechanism consisting of Amazon CloudWatch and AWS CloudTrail, with defined alerting and logging

Out-of-Scope (Exclusions):

- To ensure a deep study on the security process, this project explicitly **excludes** complex operational modules such as Hospital Billing, Pharmacy Inventory, Emergency Room (ER) management, and O&G.

5. Project Requirements:

Software	React (Frontend), Flask or Node.js (Backend), MySQL/PostgreSQL (Database), Docker (Containerization), Terraform (IaC), GitHub Actions (CI/CD), Trivy, SonarQube, and Checkov (Security Scanning).
Hardware	Amazon Virtual EC2 Instances RDS Database Instances
Technology/Technique/ Method/Algorithm	Three Tier Architecture, Infrastructure as Code (IaC), DevSecOps, CI/CD, and Agile Development.

Network Elements	Virtual Private Cloud (VPC), Public and Private Subnets, Application Load Balancer, Security Groups (Firewall), Route Tables, and Internet/NAT Gateways.
Security Elements	AWS IAM (Identity and Access Management), Role Based Access Control (RBAC), Data Encryption at Rest (AES), Encryption in Transit (TLS/HTTPS), and Automated Security Pipelines.
Project Area:	Cloud Computing and Cybersecurity (DevSecOps).

References

Ahuja, S., Mani, S., & Zambrano, J. (2012). A Survey of the State of Cloud Computing in Healthcare. *Network and Communication Technologies*, *1*. https://doi.org/10.5539/nct.v1n2p12

Al-Issa, Y., Ottom, M. A., & Tamrawi, A. (2019). EHealth Cloud Security Challenges: A Survey. In *Journal of Healthcare Engineering* (Vol. 2019). Hindawi Limited. https://doi.org/10.1155/2019/7516035

Argaw, S., Bempong-Ahun, N., Eshaya-Chauvin, B., & Flahault, A. (2019). The state of research on cyberattacks against hospitals and available best practice recommendations: A scoping review. *BMC Medical Informatics and Decision Making*, *19*. https://doi.org/10.1186/s12911-018-0724-5

Paidy, P., & Chaganti, K. (2024). Resilient Cloud Architecture: Automating Security Across Multi-Region AWS Deployments. *International Journal of Emerging Trends in Computer Science and Information Technology*, *5*(2), 82–93.

Singh, A., & Chatterjee, K. (2015). A secure multi-tier authentication scheme in cloud computing environment. *2015 International Conference on Circuits, Power and Computing Technologies [ICCPCT-2015]*, 1–7. https://doi.org/10.1109/ICCPCT.2015.7159276